PAS Audit

audited by Asymptotic

April 14, 2026

Summary

Asymptotic conducted a security audit of the Move code within the PAS framework. The audit did not identify any issues and we only issued one advisory.

PAS is a permissioned asset management framework enabling regulated fund transfers. Asset issuers can enforce compliance rules on all transfers through a configurable approval system. Assets can only move between Accounts through a hot-potato request/approval pattern requiring explicit witness authorization.

Versioning is distributed (copied into Accounts and Policies) to avoid shared object contention on Namespace. This trades instant emergency response for scalability across multiple protocols; blocked versions propagate via permissionless calls.

PolicyCap holders can freeze specific operations instantly by removing action approvals. The framework emits no events, delegating event emission to individual protocols.

PTB module is a passive data structure builder for PTB templates. It doesn't execute any logic on-chain. It only defines data structures for template construction. Security depends entirely on off-chain resolvers that consume these templates, which should validate templates before execution, including package ID validity, function existence, namespace trust. As a pure data definition layer with no on-chain execution, this module was excluded from the security audit scope.

Audited code

We audited the following directories at the given commit:

- `packages/pas/sources`
- `packages/ptb/sources`

Legend

Issue severity

- **Critical** — Vulnerabilities which allow account takeovers or stealing significant funds, along with being easy to exploit.
- **High** — Vulnerabilities which either can have significant impact but are hard to exploit, or are easy to exploit but have more limited impact.
- **Medium** — Moderate risks with notable but limited impact.
- **Low** — Minor issues with minimal security implications.
- **Advisory** — Informational findings for security/code improvements.

Legal Disclaimer

Terms and Conditions and Liability

This report is subject to the terms and conditions—including liability limitations—established between Asymptotic and the paying entity. By sharing code with Asymptotic, developers acknowledge and agree to these conditions. In the absence of executed agreements, liability is limited to the fees paid for these services.

Scope

This security audit report focuses specifically on reviewing the Move smart contract code. The audit does not analyze or make any claims about other components of the system, including but not limited to:

- Frontend applications and user interfaces
- Backend services and infrastructure
- Off-chain components and integrations
- Deployment procedures and operational security
- Third-party dependencies and external services

Limitations

The findings and recommendations in this report are limited to the Move code implementation and its immediate interactions within the Sui blockchain environment.

Issues

A-1: Order-Sensitive Approval Comparison in Request Resolution

Severity: Advisory

Description

The `resolve` function in `pas` package compares collected approvals against required approvals using positional matching via `zip_do_ref!`. Since `VecSet` maintains insertion order, two sets with identical elements inserted in different order will fail comparison.
Also, function does not verify `required_approvals` is non-empty. An empty approval set would allow requests to resolve without any witness, bypassing the approval mechanism entirely.
Currently safe because the public API (`set_required_approval`) only creates singleton sets where order is irrelevant. However, there are no other limitations on the `required_approvals` count apart from this public function. The internal `set_required_approvals` function accepts arbitrary `VecSet`, and tests already use multi-element approval sets.
If multi-approval policies are introduced, legitimate requests could fail resolution despite having all required witnesses (simply due to approval order mismatch).

Recommendation

Replace positional comparison with set membership check and prevent zero-approval resolution.

Remediation

Acknowledged - Order-dependent comparison is intentional to support future enforcement of approval ordering.

About the Auditor

Asymptotic provides a white-glove, formal-verification-based auditing service for Sui smart contracts.

Asymptotic Team

Audit Team

Lead Auditor

Mykhailo Burakhin — Principal Auditor

- Lead over 20 audits of Sui Move protocols, including some of the top CLMM, DLMM, and lending protocols
- Conducted detailed security audits and gas optimizations for complex DeFi applications
- Developed and audited ERC-20, ERC-721, and ERC-1155 token contracts, including staking, vesting, auctions, and launchpads
- Engineered cross-chain bridges using ERC-4337 account abstraction, multi-signature wallets, and upgradeable proxy contracts
- Implemented protections against anti-sniping and front-running, and secure onboarding with MPC and zero-knowledge proofs
- Over 15 years of experience architecting secure, high-performance systems with a strong focus on cryptography, blockchain security, and advanced C++ engineering